

Análisis de seguridad de una arquitectura de red híbrida

Victor Manuel Peña Flores

16 de septiembre 2025

Índice

Arquitectura de la infraestructura de red	2
Flujo de comunicación entre componentes	3
Diagrama de red	4
Tabla de direccionamiento y gateways	4
Análisis de riesgos por capa (modelo OSI/TCP-IP) y mitigaciones vistas en clase .	5
Capa L2 — Enlace de datos	6
Capa L3 — Red	7
Capa L4 — Transporte	8
Riesgos residuales	9
Pregunta abierta: VPN site-to-site vs. enlace dedicado	10

Bibliografía

12

Caso de estudio: organización con oficina rentada en el corredor Reforma/Insurgentes (Ciudad de México), infraestructura on-premises segmentada por VLANs, cargas de trabajo en una VPC en la nube, e interconexión mediante VPN site-to-site.

Arquitectura de la infraestructura de red

Segmento / Componente	Descripción y función
Internet	Punto de acceso externo desde donde se conectan usuarios y servicios públicos.
Firewall perimetral (On-Premises)	Firewall <i>stateful</i> con NAT que controla el tráfico entre Internet y la infraestructura local.
VPN Site-to-Site (IPsec)	Túnel IPsec que conecta la infraestructura on-premises con la VPC en la nube de forma cifrada.
Internet Gateway (IGW)	Puerta de enlace de la VPC que permite la comunicación entre la nube e Internet.
Subred pública – 10.0.1.0/24	Contiene los servicios expuestos a Internet, como el Application Load Balancer (ALB) y el NAT Gateway .
Application Load Balancer (ALB)	Recibe las conexiones HTTPS y distribuye las solicitudes hacia los servidores de aplicaciones en la subred privada.
NAT Gateway	Permite que los recursos de las subredes privadas accedan a Internet sin estar expuestos públicamente.
Subred privada de aplicaciones – 10.0.2.0/24	Aloja las aplicaciones y servicios internos accesibles únicamente desde el ALB o la VPN.
Subred privada de base de datos – 10.0.3.0/24	Contiene la base de datos del ERP y no tiene acceso directo a Internet.
Switch troncal (VLANs)	Distribuye el tráfico entre las VLAN de la infraestructura on-premises mediante enlaces troncales.
VLAN 10 – Datos	Red de usuarios y estaciones de trabajo (192.168.20.0/24).
VLAN 20 – VoIP	Red dedicada a teléfonos IP y servicios de voz.

Segmento / Componente	Descripción y función
VLAN 30 – Gestión	Red de administración (172.16.154.0/28) para dispositivos de infraestructura y gestión.
Servidor de colaboración – 192.168.10.10	Servicio interno de mensajería (Element/Mattermost).
Servidor de correo – 192.168.10.20	Servicio SMTP/IMAP para correo corporativo.
Servidor ERP – 192.168.10.30	Aplicación ERP conectada con la base de datos en la VPC.
Estaciones de trabajo – 192.168.20.0/24	Equipos de los usuarios conectados a la VLAN 10.

Flujo de comunicación entre componentes

Origen	Destino
Internet	Firewall perimetral (On-Premises) e Internet Gateway (VPC).
Firewall perimetral	Switch troncal y VPN Site-to-Site.
VPN Site-to-Site	Internet Gateway de la VPC.
Internet Gateway	Subred pública 10.0.1.0/24.
Application Load Balancer (ALB)	Subred privada de aplicaciones 10.0.2.0/24.
Subred privada de aplicaciones	Subred privada de base de datos 10.0.3.0/24.
Switch troncal	VLAN 10, VLAN 20 y VLAN 30.
VLAN 10	Estaciones de trabajo y servidores 192.168.10.0/24.
VLAN 20	Teléfonos IP y servicios de voz.
VLAN 30	Dispositivos de gestión y administración de la infraestructura.

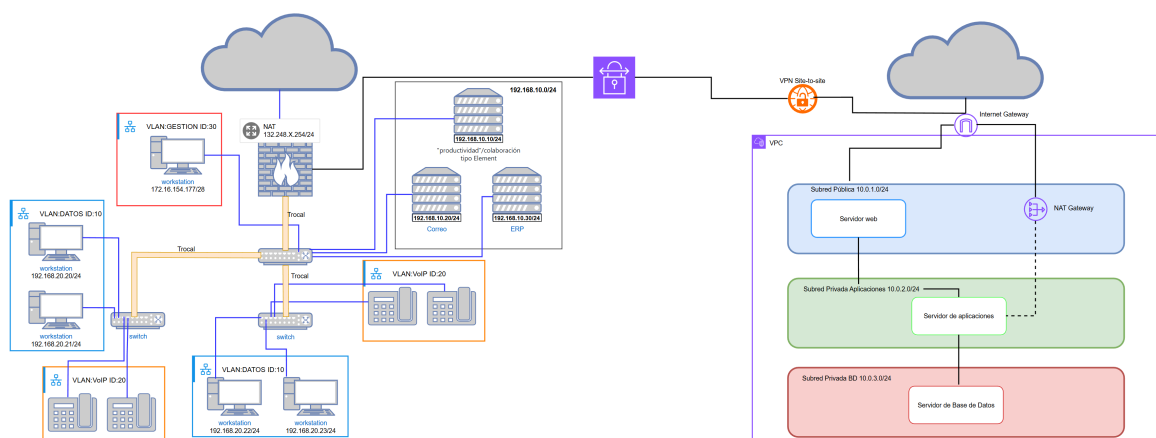


Figura 1: Diagrama de la red Híbrida

Diagrama de red

Tabla de direccionamiento y gateways

Segmento	Rango / IP	Función	Gateway / salida
Servidores on-prem	192.168.10.0/24	Correo, ERP, colaboración	Firewall perimetral (192.168.10.1 supuesto)
Estaciones de trabajo	192.168.20.0/24	VLAN 10 – Datos	Firewall perimetral
VoIP	Rango dedicado a VLAN 20 (no especificado en el diseño original — hallazgo : debe asignarse un tercer rango, p. ej. 192.168.30.0/24, distinto de datos/servidores)	Telefonía IP	Firewall / gateway de voz
Gestión	172.16.154.0/28	Fuera de banda (VLAN 30)	Firewall perimetral, aislado de datos/VoIP

Segmento	Rango / IP	Función	Gateway / salida
Firewall perimetral (externo)	132.248.X.254/24 (NAT)	Frontera Internet ↔ on-prem	ISP
VPC	10.0.0.0/16	Red virtual en la nube	—
Subred pública	10.0.1.0/24	ALB, NAT Gateway	Internet Gateway
Subred privada – Aplicaciones	10.0.2.0/24	Servidores web/app	NAT Gateway (solo saliente)
Subred privada – BD	10.0.3.0/24	Base de datos	Sin ruta a Internet
Interconexión	Túnel(es) IPsec S2S	On-prem ↔ VPC	Firewall perimetral ↔ Virtual Private Gateway

Análisis de riesgos por capa (modelo OSI/TCP-IP) y mitigaciones vistas en clase

Se analizan riesgos por capas vistas en clase, aplicables a esta arquitectura: **L1 Física, L2 Enlace de datos, L3 Red, L4 Transporte, L7 Aplicación** (las capas 5-6, Sesión y Presentación, no se tratan por separado porque la pila TCP/IP las funde en la capa de aplicación). Impacto evaluado sobre **C**onfidencialidad, **I**ntegridad, **D**isponibilidad. Cada capa se ancla a elementos concretos del caso (on-prem, VLANs, VPC, VPN) para trazabilidad con la sección 4.

Capa OSI	Dónde aplica en este caso
----------	---------------------------

L2 Enlace Switch troncal y VLANs 10/20/30
L3 Red Direccionamiento IP, firewall/NAT, túnel IPsec (encapsula IP sobre IP)
L4 Transporte Sesiones TCP del firewall stateful, tráfico interno correo/ERP

Capa L2 — Enlace de datos

L2-1. VLAN hopping (switch spoofing / double tagging)

Descripción: un atacante conectado a un puerto de acceso negocia manualmente el modo *trunk* (si el protocolo de negociación de enlaces troncales no está deshabilitado) o inyecta tramas con doble etiqueta 802.1Q para saltar de una VLAN a otra sin pasar por el firewall/router (Farrow, 2003).

- *Superficie de ataque:* cualquier puerto de switch físicamente accesible (agravado por el hallazgo L1-1 de acceso físico compartido).
- *Impacto CIA:* Confidencialidad e Integridad **altas** — permite alcanzar la VLAN de servidores o gestión evitando el control de acceso previsto.
- *Probabilidad:* media-alta en este entorno específico; documentado como vector práctico en Rouiller, “*Virtual LAN Security: Weaknesses and Countermeasures*” (SANS Institute) y referenciado en el estándar IEEE 802.1Q.
- *Mitigación:* deshabilitar la negociación automática de enlaces troncales (modo *access* fijo), no usar la VLAN nativa por defecto para tráfico real, *port security* (limitar direcciones MAC por puerto), 802.1X para autenticación de puerto.

L2-2. ARP spoofing / envenenamiento (man-in-the-middle dentro de una VLAN)

Descripción: el protocolo ARP (RFC 826) no autentica respuestas; un host malicioso en la misma VLAN puede anunciarse como el gateway y interceptar tráfico de otros hosts. Una variante relacionada es el *MAC flooding* de la tabla CAM del switch, que puede forzarlo a un comportamiento tipo hub, facilitando la escucha pasiva (Networks, 2024).

- *Superficie de ataque:* cualquier estación dentro de VLAN 10 (Datos), donde conviven usuarios y — según el diseño actual — también los servidores.
- *Impacto CIA:* Confidencialidad **alta** (intercepción de credenciales/tráfico interno); Integridad media (posible modificación en tránsito).
- *Probabilidad:* alta si servidores y estaciones comparten dominio de broadcast (como se señaló en el diseño actual), porque cualquier endpoint comprometido por phishing queda en posición de interceptar tráfico hacia los servidores críticos.

- *Mitigación:* Dynamic ARP Inspection (DAI) + DHCP snooping en el switch, segmentación real de servidores en su propia VLAN, límite de direcciones MAC por puerto contra *flooding*.

Capa L3 — Red

L3-1. IP spoofing

Descripción: el atacante falsifica la IP origen de un paquete para que parezca venir de una red de confianza (ej. la VLAN de Gestión, 172.16.154.177), y así engañar al firewall que solo valida por esa IP, sin comprobar por qué VLAN/interfaz entró realmente (Ferguson & Senie, 2000).

- *Superficie de ataque:* el firewall perimetral (132.248.X.254) en su interfaz externa, por no validar que un paquete entrante realmente provenga de la red que declara como origen (ej. 172.16.154.X de VLAN Gestión, o 192.168.10.X/192.168.20.X); también cualquier host interno que no valide su propio tráfico saliente.
- *Impacto CIA:* si en vez de solo “colarse” el atacante usa un servidor tuyo (Correo, ERP, Element) como reflector en un ataque de amplificación, tu red termina caída de servicio (disponibilidad) y encima puede quedar en listas negras por el tráfico malicioso que salió “desde ti” hacia terceros — aunque tú nunca lo generaste (por eso integridad baja: no te robaron ni alteraron datos, solo abusaron de tu origen).
- *Probabilidad:* media — los ataques volumétricos basados en spoofing siguen siendo la categoría dominante de incidentes de disponibilidad en Internet (RFC 4732, *Internet Denial-of-Service Considerations*).
 - *Mitigación:* *ingress/egress filtering* (BCP 38 / RFC 2827) en el firewall perimetral, anti-spoofing explícito (descartar en la interfaz externa cualquier paquete con IP origen perteneciente a los rangos internos).

L3-2. ICMP Redirect Spoofing

Descripción: El atacante envía ICMP Redirect falsos para intentar modificar la ruta que utiliza un equipo y hacer que su tráfico pase por un dispositivo controlado por el atacante (Mazerik, 2018).

- *Superficie de ataque:* Equipos y dispositivos de red que aceptan mensajes ICMP Redirect dentro de la red.
- *Impacto CIA:* Confidencialidad **alta** el atacante podría interceptar el tráfico; Integridad: **alta** podría modificar o manipular la comunicación.
- *Probabilidad:* baja-media - ya que depende de que los dispositivos acepten mensajes ICMP Redirect falsificados.
- *Mitigación:* - Deshabilitar la aceptación de ICMP Redirect cuando no sea necesario. - Utilizar segmentación de red y mecanismos de filtrado.

Capa L4 — Transporte

L4-1. SYN flood / agotamiento de estado en el firewall stateful

Descripción: saturación de la tabla de sesiones del firewall mediante un volumen elevado de segmentos TCP SYN que nunca completan el *three-way handshake*, agotando los recursos de seguimiento de estado (*RFC 4987: TCP SYN Flooding Attacks and Common Mitigations*, s/f).

- *Superficie de ataque:* Firewall perimetral con NAT e IP pública, expuesto directamente a Internet y encargado de gestionar el tráfico hacia la infraestructura on-premises y el túnel VPN Site-to-Site con la VPC.
- *Impacto CIA:* Confidencialidad baja, Integridad baja, Disponibilidad alta, ya que puede impedir el acceso a los servicios de correo (192.168.10.20), ERP (192.168.10.30), plataforma de colaboración y aplicaciones alojadas en la VPC a través de la VPN.
- *Probabilidad:* Media. El firewall perimetral constituye el principal punto de entrada desde Internet y puede ser objetivo de ataques de denegación de servicio dirigidos a agotar su capacidad de mantener conexiones TCP.
- *Mitigación:* Habilitar mecanismos de protección frente a SYN Flood en el firewall (SYN cookies o SYN proxy, según el fabricante), aplicar rate limiting para conexiones TCP SYN por dirección de origen, implementar filtrado anti-spoofing y, cuando sea posible, utilizar protección anti-DDoS o servicios de scrubbing proporcionados por el ISP. La redundancia del enlace o del firewall reduce el impacto sobre la disponibilidad del servicio.

L4-2. Secuestro de sesión TCP (session hijacking) en tráfico interno sin cifrar

Descripción: si el tráfico entre estaciones y servidores (correo/ERP) no está cifrado de extremo a extremo, un atacante posicionado *on-path* (facilitado por L2-2, ARP spoofing) puede inyectarse en una sesión TCP establecida o tomar su control, sin necesidad de predecir números de secuencia si ya intercepta el flujo completo (Morris, 1986).

- *Superficie de ataque:* sesiones TCP no cifradas dentro de VLAN 10 (Datos).
 - *Impacto CIA:* Integridad **alta** (inyección/modificación de datos en tránsito), Confidencialidad alta.
 - *Probabilidad:* media — depende de lograr primero una posición *on-path* (vía L2-2), pero una vez lograda, la ausencia de cifrado interno la hace trivial de explotar.
 - *Mitigación:* TLS de extremo a extremo también en tráfico interno (no solo perimetral), aleatorización robusta del número de secuencia inicial (estándar en pilas TCP modernas, RFC 6528), y reducción de la superficie *on-path* mediante la segmentación de L2-2.
-

Riesgos residuales

Incluso con las mitigaciones anteriores aplicadas, persisten riesgos que ninguna medida técnica elimina por completo:

1. **On-premises — acceso físico en edificio compartido.** Ninguna mitigación de red evita que alguien con acceso físico al cuarto de telecomunicaciones compartido del edificio (corredor Reforma/Insurgentes) conecte un dispositivo no autorizado o intercepte cableado, si el rack no tiene gabinete propio con control de acceso. *Acción concreta:* auditoría física trimestral del MDF/IDF, gabinete con cerradura independiente del resto del edificio, CCTV y bitácora de visitantes.
2. **Nube — deriva de configuración (configuration drift) en el tiempo.** Las políticas de Security Groups y roles IAM correctamente definidas hoy tienden a relajarse con el tiempo por cambios operativos no documentados (exactamente el mismo patrón de

“rule creep” que afecta al firewall on-prem, pero en la nube). *Acción concreta:* escaneo continuo con AWS Config/CIS Benchmarks y revisión trimestral obligatoria de IAM y Security Groups.

3. **Interconexión — dependencia de un solo proveedor de última milla.** Aun con dos túneles VPN redundantes a nivel de AWS, si ambos cruzan el mismo ISP/última milla en la oficina (situación común en un solo circuito de Internet contratado), un corte físico de ese proveedor tumba ambos túneles simultáneamente. *Acción concreta:* segundo proveedor de Internet (ISP distinto) para diversidad de ruta, o considerar el enlace dedicado que se analiza en la sección 5.
4. **Transversal — el usuario como superficie no mitigable por completo.** MFA y filtros reducen drásticamente el phishing exitoso, pero no lo eliminan (fatiga de MFA, ingeniería social telefónica). *Acción concreta:* programa continuo de concientización con simulacros de phishing y métricas de mejora, no solo capacitación puntual.

Pregunta abierta: VPN site-to-site vs. enlace dedicado

Sustituir la VPN S2S (Novikava, 2026) por un **enlace dedicado** (circuito privado tipo MPLS, o un servicio de interconexión directa a la nube como AWS Direct Connect) cambia el análisis en varios sentidos:

Superficie de ataque:

- Se elimina la exposición del endpoint IKE/IPsec a Internet — ya no hay un servicio público de VPN que pueda ser escaneado, sometido a fuerza bruta de PSK, o atacado por denegación de servicio dirigida al puerto IKE (UDP 500/4500). Esa clase completa de ataques (capa E1/E2 de este análisis) desaparece del modelo de amenazas.
- A cambio, aparece una nueva superficie física: el circuito dedicado en sí (par de cobre/fibra provisto por el carrier) puede ser objeto de interceptación física o corte, y la seguridad ya no depende de criptografía sino de la integridad física del circuito y del carrier.

Mitigaciones en capa de enlace/red que cambian:

- El cifrado ya no se resuelve con IPsec sobre Internet, sino — si se requiere confidencialidad en tránsito, que sigue siendo recomendable aunque el circuito sea “privado” — con **MACsec (IEEE 802.1AE)** (802.1AE: *MAC Security (MACSEC)*), s/f) a nivel de enlace, cifrando trama por trama entre los equipos de borde.
- Si el enlace dedicado usa BGP para intercambiar rutas (común en Direct Connect), se vuelve necesario aplicar las prácticas de RFC 7454 (*BGP Operations and Security*) (Durand et al., 2015): autenticación de sesión BGP (MD5/TCP-AO), filtrado de prefijos, límites de rutas aceptadas.
- La segmentación por VLAN y las políticas de Security Group del lado de la nube no cambian — siguen siendo necesarias exactamente igual, porque el enlace dedicado solo resuelve el transporte, no el control de acceso entre subredes.

Costo/beneficio de seguridad:

- **A favor:** menor superficie de ataque expuesta a Internet, latencia más predecible (relevante si hay aplicaciones sensibles a jitter, como VoIP cruzando el enlace), throughput garantizado por SLA en vez de “mejor esfuerzo”.
- **En contra:** costo significativamente mayor (circuito dedicado + tiempos de aprovisionamiento de semanas/meses, frente a un túnel VPN configurable en horas), y sigue existiendo un punto único de falla física si no se contrata diversidad de ruta — el enlace dedicado no resuelve por sí solo el riesgo residual #3 de la sección anterior, solo lo traslada de “ataque a un endpoint público” a “corte físico de un circuito”, que sigue requiriendo redundancia (segundo circuito o VPN de respaldo) para eliminarse.
- **Conclusión práctica:** para una organización de este tamaño (oficina rentada, sin indicios de tráfico de altísima sensibilidad regulatoria), el costo del enlace dedicado probablemente no se justifica frente a una VPN S2S bien configurada (IKEv2, doble túnel, certificados) — el enlace dedicado se vuelve razonable si el volumen de tráfico entre on-prem y nube crece considerablemente, o si aparecen requisitos regulatorios/contractuales que exijan explícitamente no transitar Internet.

Bibliografía

- 802.1AE: MAC Security (MACSEC) |. (s/f). <https://1.ieee802.org/security/802-1ae/>
- Durand, J., Pepelnjak, I., & Doering, G. (2015). *BGP Operations and Security*. <https://doi.org/10.17487/rfc7454>
- Farrow, R. (2003). *Network defense, VLAN INSECURITY*. <https://rikfarrow.com/Network/>
- Ferguson, P., & Senie, D. (2000). *Network Ingress Filtering: Defeating Denial of Service Attacks which employ IP Source Address Spoofing*. <https://doi.org/10.17487/rfc2827>
- Mazerik, R. (2018). *ICMP attacks*. <https://doi.org/10.17487/rfc2827>
- Morris, R. (1986). A Weakness in the 4.2BSD Unix TCP/IP Software. *A Weakness in the 4.2BSD Unix TCP/IP Software*. <http://nil.lcs.mit.edu/rtm/papers/117.pdf>
- Networks, J. (2024). *Ejemplo: Protección contra ataques de suplantación de ARP | Junos OS | Juniper Networks*. <https://www.juniper.net/documentation/mx/es/software/junos/security-services/topics/example/port-security-protect-from-arp-spoofing.html>
- Novikava, A. (2026). *What Is a Site-to-Site VPN and How Does It Work?* <https://nordlayer.com/blog/what-is-site-to-site-vpn/>
- RFC 4987: TCP SYN Flooding Attacks and Common Mitigations. (s/f). <https://datatracker.ietf.org/doc/rfc4987/>